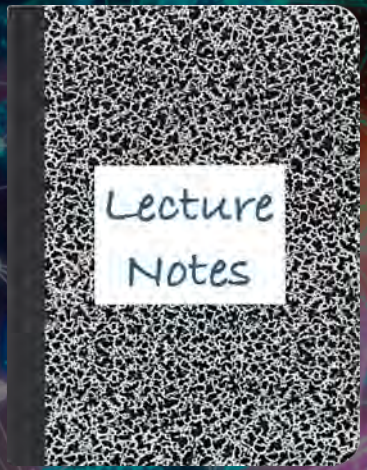
CS 419 – Computer Security

Week 4 Recitation

Biometric Authentication and Review



Paul Krzyzanowski

© 2026 Paul Krzyzanowski. No part of this content may be reproduced or reposted in whole or in part in any manner without the permission of the copyright owner.

What This Session Covers

Freshness and evidence — Which mechanism each protocol uses, and who gets proof that a key is new

Keys and adversaries — What stops an adversary in the middle, and what a stolen key exposes

Biometrics — Scores, thresholds, error rates, and what a biometric cannot do

Secure Communication: Review

Three Ways to Show Freshness

Mechanism	The receiver needs	Used in	Its limitation
Nonce	To remember the challenge it sent	Needham-Schroeder, challenge-response	An extra message to send the challenge
Timestamp	A clock that agrees with the sender's	Kerberos, the Denning-Sacco fix	Replays inside the window, unless remembered
Sequence number	A counter for the session	TLS records, car remotes	State on both sides; gaps and restarts

Each one answers the same question: **is this message new, or a copy of an old one?**

Who Gets Proof of a Fresh Key

Needham-Schroeder	Denning-Sacco fix	Kerberos
Alice's nonce r_1 comes back inside Trent's reply.	Trent adds a timestamp to the ticket.	Tickets have validity periods; authenticators carry the time.
Alice Her nonce shows the key is new.	**Alice** Still has her nonce.	**Alice** Gets fresh tickets from the KDC.
Bob Only a ticket, which could be old.	**Bob** Checks the ticket's timestamp.	**The service** Checks each authenticator's time.

Stopping the Adversary in the Middle

	What the adversary tries	What stops it
Unsigned Diffie-Hellman	The adversary swaps in its own g^m in both directions.	Nothing. Each side shares a key with the adversary.
Signed Diffie-Hellman	The adversary replaces the server's share.	The signature over the share fails to verify.
TLS 1.3	The adversary alters a message in the handshake.	The server signs the transcript; both sides check a MAC.
Passkeys	A phishing site relays the site's challenge.	The browser blocks the lookalike domain; the signature covers the origin.

Keys and What Their Loss Exposes

Key	How long it lasts	If an attacker obtains it
Server's RSA key used for key transport	Years	**Every recorded session** it ever protected, plus impersonation
Server's TLS 1.3 signing key	Years	Impersonation from now on; recorded sessions stay secret
Ephemeral Diffie-Hellman secret	One handshake, then erased	That one handshake's session keys
Session key	One connection	That connection's traffic
Kerberos key derived from a password	Until the password changes	Requests to the KDC as that user; tickets encrypted with it can be guessed offline

Matching Password Attacks to Defenses

What the attacker does	Attack	Defense
Steals a database of unsalted SHA-256 hashes	Offline guessing with precomputed tables	**Salt**, and a **slow hash** such as *bcrypt* or *Argon2*
Tries email and password pairs leaked from another site	**Credential stuffing**	Checking passwords against breach lists, a second factor
Tries Winter2024! once against every account	**Password spraying**	Watching failures across accounts, a second factor
Sends a lookalike login page that forwards codes	Real-time relay	Passkeys, bound to the site's origin
Tries thousands of guesses on one account	Online guessing	Rate limiting and lockout delays

Biometric Authentication

Matching a Measurement, Not a Secret

A password check

```
if hash(salt + pw) == stored:
    accept()
```

The same password always produces the same hash. A match is **exact**.

A biometric check

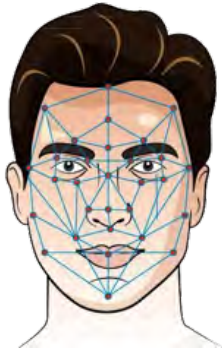
```
f = extract_features(scan)
d = distance(f, template)
if d <= threshold:
    accept()
```

Angle, pressure, skin condition and quality of sensing change every scan. A match is **close enough**, and the **threshold** decides what that means.

Biometric Authentication Modalities

Face

- Face geometry
- w/ 3-D imaging
- Thermographs
- Ear imaging



Eyes

- Iris - spokes
- Retinal scans





Hands

- Fingerprints
- Vein scans
- Hand geometry
  - Finger length
  - Contours
  - Surface are



Signature, Voice

Behavioral vs. **physical** biometrics

Behavioral:

- Voice
- Signature
- Typing rhythm
- …

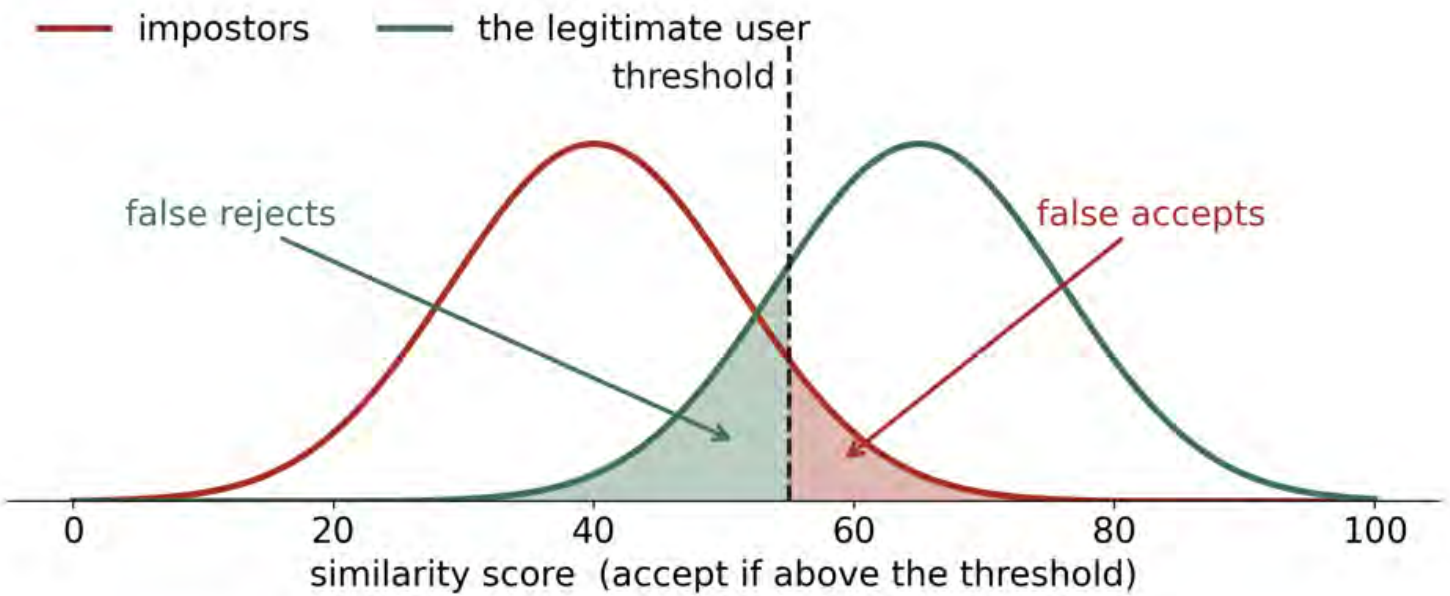


Others

- DNA
- Odor
- Gait
- Typing rhythm
- Driving habits
- …

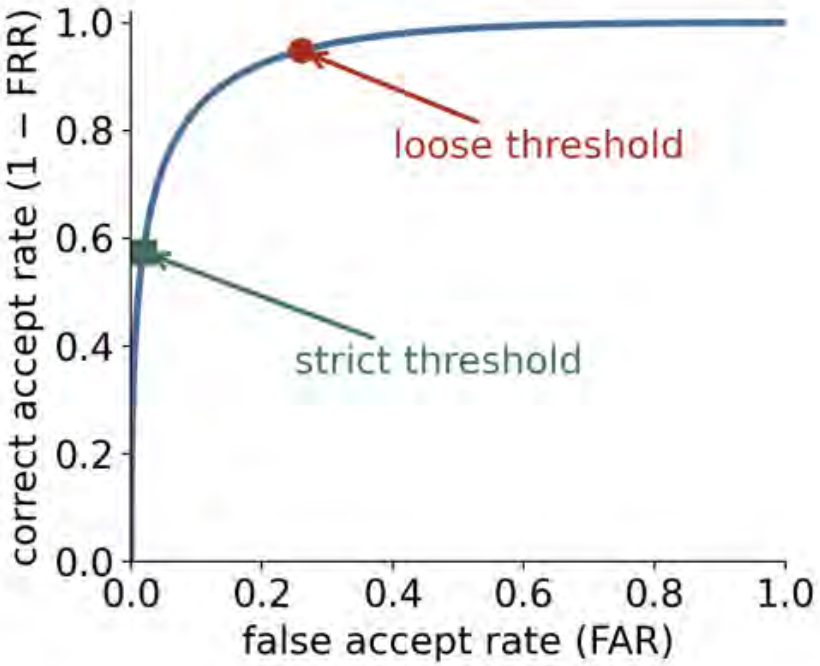


Scores and a Threshold



Wherever the threshold goes, some impostors score above it and some real scans score below it.

Measuring the Tradeoff



ROC curve

Every error combination the system can reach

The threshold picks a point

Better sensors, matchers, or enrollment move the curve.

FAR and FRR

Impostors accepted; user rejected

A design choice

Forgiving or strict depends on what each error costs

Choosing an Operating Point

An **operating point** is the threshold a deployment chooses, and the error rates that come with it.

Favor convenience	Favor security
A car door The owner expects it to open on the first try, in the cold or with wet hands. Repeated rejections send owners back to the key.	**A high-security gate or a safe** A rejected employee can try again or call a guard. An impostor must not get in.

The same sensor and matcher can serve both, with **different thresholds**.

Operating Points on Phones

1 in 50,000

A stranger matches one enrolled fingerprint (Touch ID)

< 1 in 10^6

A stranger matches one enrolled face (Face ID)

5

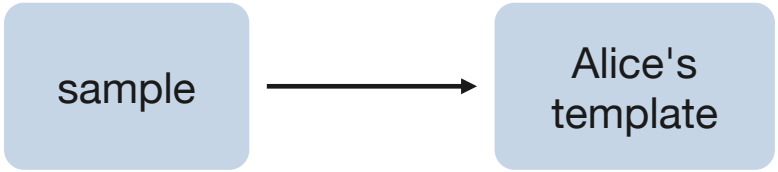
Failed attempts before the passcode is required

For comparison, a random guess at a four-digit PIN succeeds 1 in 10,000 times.

These figures measure chance matches.
They do not measure a targeted spoof, and Face ID's false-match risk is higher for twins, similar-looking siblings, and young children.

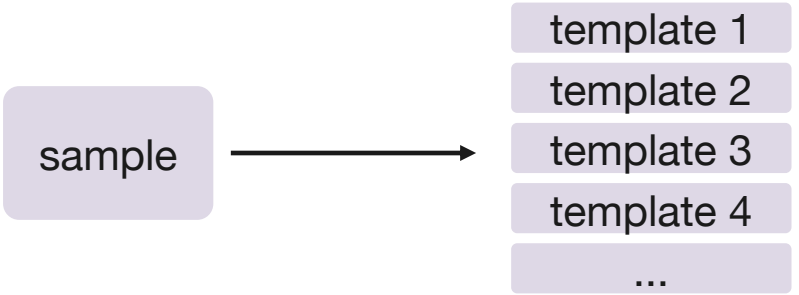
Verification and Identification

Verification: "Is this Alice?"



one comparison: **1:1**

Identification: "Who is this?"

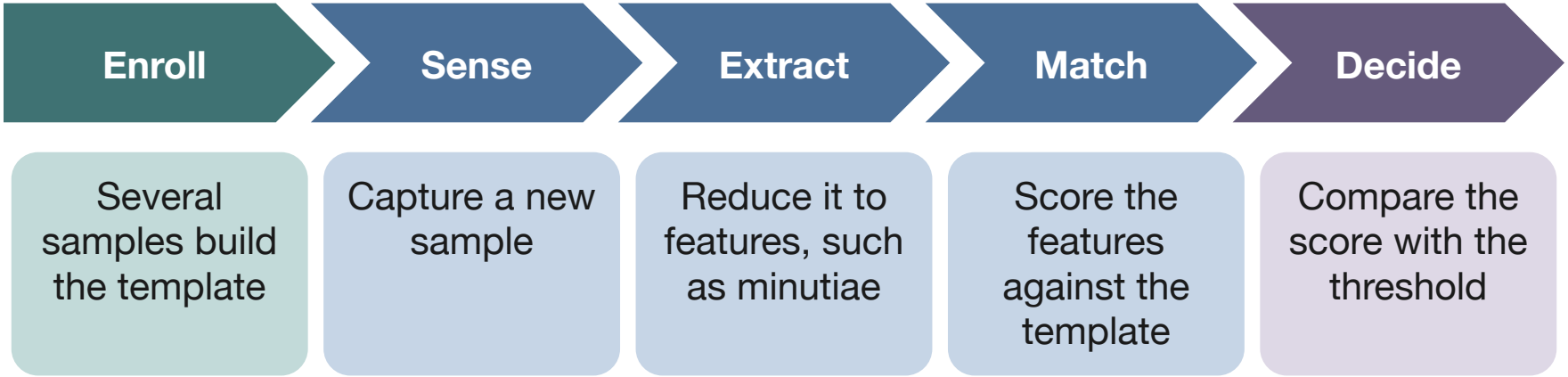


one comparison per template: **1:N**

A false match rate of 1 in a million means one mistake per million logins.

The same rate, searching a million templates, gives about **one false match per search**.

The Enrollment and Matching Pipeline



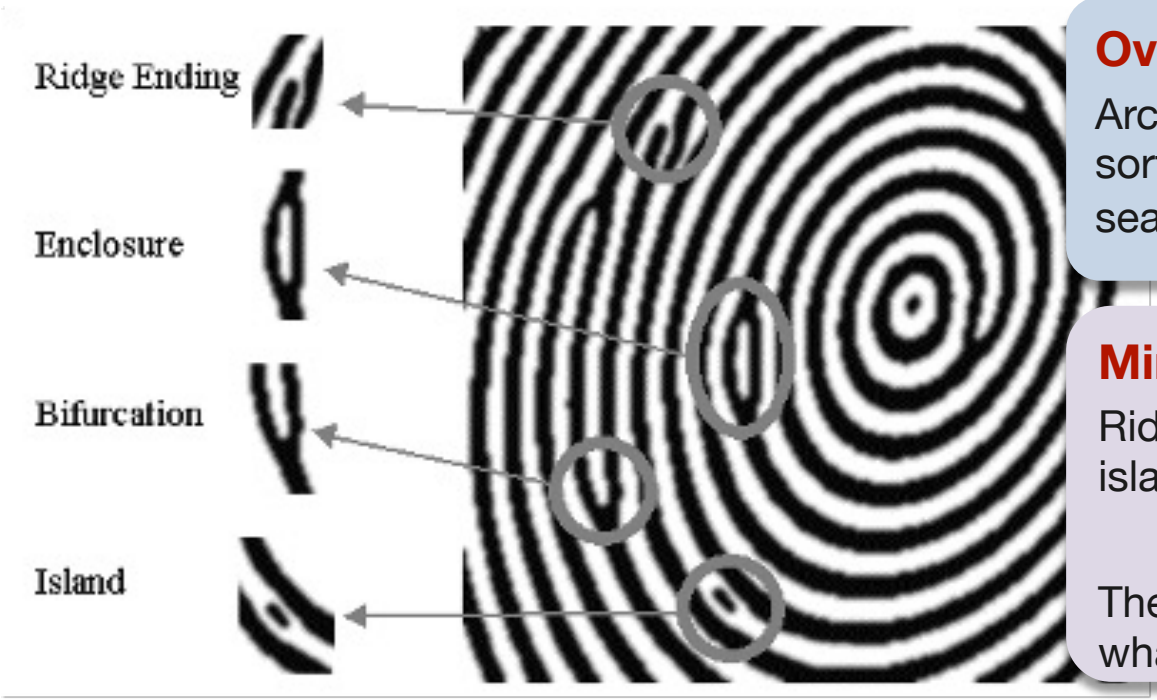
Minutiae

The points where fingerprint ridges end or split. Matchers compare their positions and directions.

Enrollment is done once

A poor template causes poor matching for as long as it stays in use.

Feature Identification in Fingerprints



Overall ridge pattern

Arches, loops, and whorls. Used to sort prints into classes before a search.

Minutiae

Ridge endings, bifurcations, islands, bridges, and enclosures.

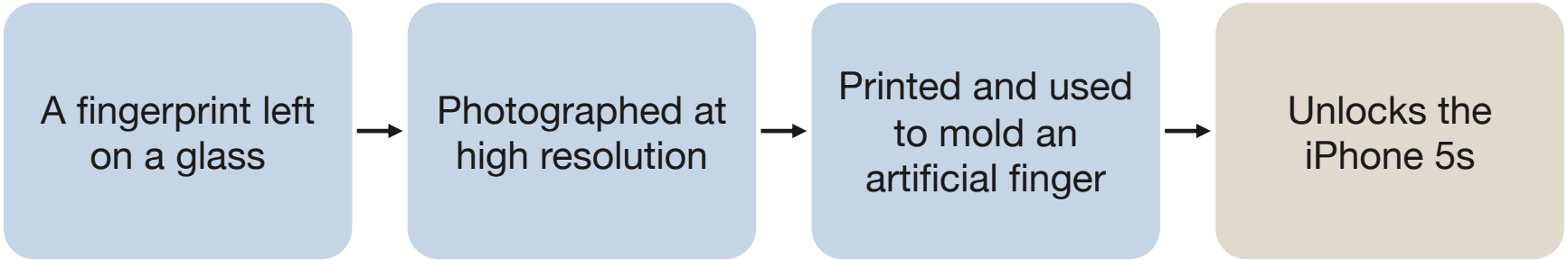
Their positions and directions are what the matcher compares.

A matcher compares the arrangement of minutiae, not the image pixel by pixel.

Irises and Fingerprints: A Comparison

	Fingerprint	Iris
Features compared	A few dozen minutiae	A few hundred texture features
Stability	Wear, cuts, and dry skin change the print	Changes little over adult life
Capture	Contact sensor; smudges and gloves interfere	Camera with near-infrared light; the user must look at it
Searching	Cannot be fully normalized, so large searches are slow	Encoded as a fixed-length bit string, so comparisons are fast
Spoofing	Prints are left on everything a person touches	Photos with a contact lens fooled a phone scanner (2017)
Typical use	Phones, laptops, and door locks	Border control and national ID systems

Presentation Attacks



In September 2013, days after the iPhone 5s went on sale, the Chaos Computer Club, a German hacker association, showed that Touch ID accepted a fake finger made this way.

A **presentation attack** fools the sensor with a substitute: a photograph, a mask, a molded finger, or a recorded voice.

Recent Presentation Attacks

Molded fingerprints (April 2020)

Researchers at Cisco Talos cast fabric glue in 3D-printed molds made from prints on glass, sensor images, and direct contact.

The fakes unlocked most phones and laptops tested, about 80 percent of the time.

A cloned voice (February 2023)

A Vice reporter used a free voice-cloning service and about five minutes of recorded speech to pass Lloyds Bank's voice authentication for his own account.

Fingerprints, faces, and voices are left on glasses, in photos, and in recordings.

The tools to copy them have become cheaper and more capable.

Defending the Sensor

Example: Silicone covers

In October 2019, Samsung reported that certain silicone covers caused some Galaxy S10 and Note10 phones to accept the cover's pattern as the owner's fingerprint.

The fix was a software patch and re-enrollment.

Liveness detection

Looks for blood flow or skin properties under a finger, or a depth map of a face that a photo or video lacks.

A thin fake film over a real finger can still pass.

The sensor path

An attacker who injects data between the sensor and the matcher skips the sensor's checks.

Secure designs protect that path and keep matching away from the main operating system.

Protecting Templates

A salted hash works for passwords because the match is exact. Hashing two nearby scans gives **unrelated** outputs, so it cannot be used for biometrics.

Store features

Keep extracted features instead of raw images.

The features are still sensitive.

Secure hardware

Keep templates and matching in a secure processor on the device.

The service never collects the biometric.

Cancelable biometrics

Transform the features before storing them.

A new transformation replaces a leaked template, but not the finger.

Problems With Biometrics

It cannot be revoked

Ten fingers, two irises, one face.

The 2015 OPM breach exposed 5.6 million people's fingerprints.

Cannot be compartmentalized

One password per site is possible.

One finger per site is not.

It lacks a canonical form

Scans differ in rotation, position, and pressure. Iris codes are a partial exception.

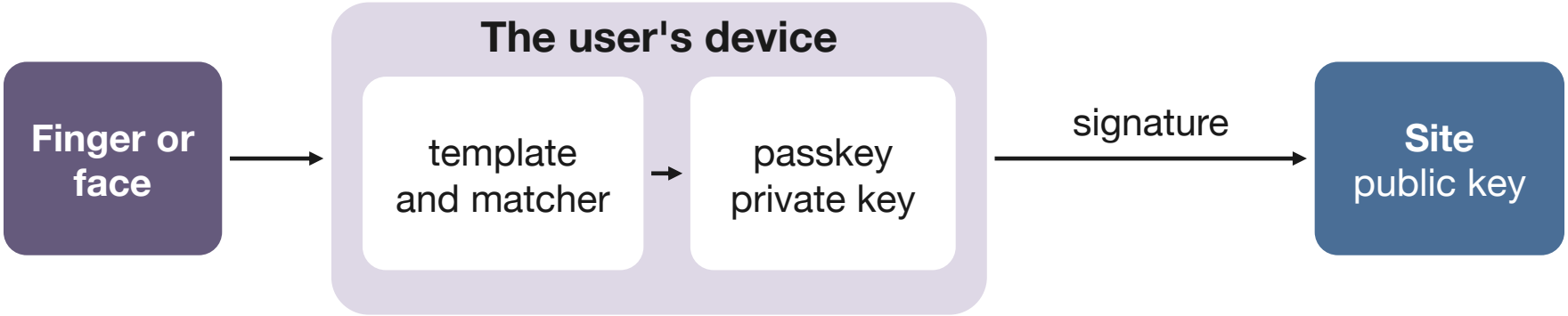
It can be taken by force

In 2005, car thieves in Malaysia cut off the end of an owner's finger to restart his car.

It is not equally accurate for everyone

A 2019 NIST study found false-match rates differing 10 to 100 times across groups.

Where Biometrics Fit



The site never sees the biometric

The template stays on the device. The site stores a public key, which it can revoke and replace.

What a spoof still gets

A stolen template does not reveal the private key. A successful spoof unlocks the device and lets the attacker use it.

The End